

**Cybersecurity Risk Assessment
Lakeside Medical Center
Patient Information System**

By: Ilana Ford

Table of Contents

1. Executive Summary.....	3
2. Assessment Objective.....	3
3. Scenario.....	3
4. Asset Inventory.....	3
5. Threat Identification.....	4
6. Vulnerability Assessment.....	5
7. Risk Analysis.....	7
8. Security Control Recommendations...	9
9. Residual Risk Assessment.....	11
10. Residual Risk Conclusion.....	12

1. Executive Summary

This cybersecurity risk assessment was conducted to identify and evaluate risks associated with Lakeside Medical Center's cloud-based Patient Information System. The assessment focused on threats that could affect the confidentiality, integrity, and availability of sensitive patient information and healthcare systems.

Five cybersecurity risks were identified, including compromise of a patient check-in tablet, phishing attacks targeting employee accounts, lost or stolen devices, insider misuse, and system failure. The initial risk levels ranged from Medium to High. Recommended security controls include network access controls, multi-factor authentication, cybersecurity awareness training, access controls, encryption, least privilege, security monitoring, system updates, load balancing, and redundancy.

After considering the recommended controls, the residual risk for each identified risk was assessed as Low. Implementing these controls can strengthen Lakeside Medical Center's cybersecurity posture, better protect sensitive patient information, and reduce the likelihood and potential impact of cybersecurity incidents.

2. Assessment Objective

Assess cybersecurity risks associated with Lakeside Medical Center's Patient Information System, identify potential threats and vulnerabilities, evaluate the likelihood and impact of identified risks, and recommend appropriate security controls to reduce organizational risk.

3. Scenario

Lakeside Medical Center is a fictional mid-sized healthcare organization with approximately 500 employees across five clinics and a central administrative office. The organization uses a cloud-based Patient Information System to store and manage sensitive patient information. Employees access the system from both organizational facilities and remote locations. Following an increase in phishing attempts targeting employees, management has requested a cybersecurity risk assessment to identify significant risks and determine appropriate security controls.

4. Asset Inventory

Information Assets

- Patient medical records

- Payment information
- Patient personal/demographic information

Systems/Applications

- Cloud-based Patient Information System
- X-ray/imaging application

Devices

- Desktop computers used at medical facilities
- Patient check-in tablets

Identities/Accounts

- Doctors/medical providers
- Pharmacy technicians
- Patients

Security Requirement

- Access should follow least privilege and be based on the user's role. Patients should only be able to access their own information.

5. Threat Identification

Threat 1: Malicious External Actor Compromises Patient Check-In Tablet

- **What could happen:** A malicious external actor could compromise a patient check-in tablet and display false or damaging messages to patients.
- **Asset(s) affected:** Patient check-in tablets
- **Potential impact:** Reputational damage and disruption to patient check-in operations.

Threat 2: Phishing Attack

- **What could happen:** An employee/provider could receive a fraudulent email designed to obtain their login credentials. If the employee provides their credentials, an attacker could gain unauthorized access to the employee/provider account and potentially access confidential patient information.
- **Asset(s) affected:** Employee/provider accounts and patient medical information

- **Potential impact:** Unauthorized access to confidential patient information.

Threat 3: Lost or Stolen Device

- **What could happen:** A device used by an employee for remote work could be lost or stolen. If the device is not properly protected, an unauthorized person could potentially access information or accounts stored on or accessible through the device.
- **Asset(s) affected:** Patient medical information, prescription information, and patient accounts
- **Potential impact:** Unauthorized access or exposure of patient information.

Threat 4: Insider Misuse

- **What could happen:** An employee could intentionally access a patient's medical record even though the information is not necessary for the employee's job responsibilities.
- **Asset(s) affected:** Patient Information System and patient medical records
- **Potential impact:** Unauthorized access to confidential patient information.

Threat 5: System Failure

- **What could happen:** The Patient Information System could become unavailable because of a technical or system failure.
- **Asset(s) affected:** Patient Information System
- **Potential impact:** Disruption to access to patient information and healthcare operations.

6. Vulnerability Assessment

Threat 1: Malicious External Actor Compromises Patient Check-in Tablet

Vulnerabilities:

- Inadequate network access controls could allow unauthorized traffic or devices to communicate with the tablet.

- Unrestricted access to system settings and the tablet doesn't sufficiently restrict unauthorized users from changing settings.

Threat 2: Phishing Attack

Vulnerabilities:

- Lack of cybersecurity awareness training may leave employees unable to distinguish legitimate emails from phishing attempts.
- Lack of SPF could make it easier for attackers to spoof Lakeside's email domain.
- Lack of MFA, stolen credentials alone may be sufficient for an attacker to authenticate.

Threat 3: Lost or Stolen Device

Vulnerabilities:

- The device has insufficient access restrictions, potentially allowing an unauthorized person who obtains the device to access organizational resources.
- The device relies on a password that is easy to guess, increasing the likelihood of unauthorized access.
- Weak encryption could allow an unauthorized person who obtains the device to read confidential data.

Threat 4: Insider Misuse

Vulnerabilities:

- Lack of role-based and attribute-based access controls could allow employees to access systems or information that are not necessary for their specific roles.
- Employees do not have strict access boundaries within the system, which could allow them to access information that is not required for their job functions.
- Lakeside does not adequately monitor employee activity, making it difficult to detect and investigate suspicious or unauthorized activity.

Threat 5: System Failure

Vulnerabilities:

- Lack of regular system updates could increase the likelihood of system errors or failures.
- The system may lack adequate capacity or traffic distribution mechanisms, increasing the risk of an outage during periods of high demand.
- Lack of system redundancy could create a single point of failure, leaving the Patient Information System unavailable if a critical component fails.

7. Risk Analysis

Risk Rating Matrix:

Likelihood	Impact	Overall Risk
High	High	High
Medium	High	Medium
Low	Medium	Low

Threat 1: Malicious External Actor Compromises Patient Check-In Tablet

Likelihood: High

- **Reason:** The check-in tablet is located in an area accessible to the public, increasing the opportunity for an unauthorized person to physically interact with or attempt to compromise the device.

Impact: High

- **Reason:** A successful compromise could negatively affect patient trust and the reputation of Lakeside Medical Center. It could also affect the integrity and availability of the patient check-in system.

Overall Risk: High

Threat 2: Phishing Attack

Likelihood: High

- **Reason:** Lakeside Medical Center has experienced an increase in phishing attempts targeting employees, making a successful phishing attack more likely.

Impact: High

- **Reason:** A successful phishing attack could compromise an employee or provider account and allow an attacker to access confidential patient medical records.

Overall Risk: High**Threat 3: Lost or Stolen Device****Likelihood: Medium**

- **Reason:** The device has an easy-to-guess password that increases the chance of unauthorized access, but the other vulnerabilities don't necessarily make the loss/theft itself more likely. Although the device could be lost or stolen, those events do not necessarily result in a compromise of the information stored on or accessible through the device.

Impact: High

- **Reason:** A lost or stolen device could expose sensitive patient medical and prescription information, potentially resulting in a HIPAA violation and harm to patient privacy.

Overall Risk: Medium**Threat 4: Insider Misuse****Likelihood: Medium**

- **Reason:** Employees may have access to patient information that is not necessary for their job functions because of insufficient access controls. However, having unnecessary access does not necessarily mean an employee will intentionally misuse that access.

Impact: High

- **Reason:** Unauthorized access to patient medical records could expose sensitive patient information, compromise patient privacy, and potentially result in regulatory or legal consequences for Lakeside Medical Center.

Overall Risk: Medium

Threat 5: System Failure

Likelihood: High

- **Reason:** The lack of system redundancy increases the likelihood that a failure of a critical system component could make the Patient Information System unavailable. In addition, the lack of regular system updates and sufficient system capacity or traffic distribution could increase the risk of system failures and service disruptions.

Impact: High

- **Reason:** An unavailable Patient Information System could prevent healthcare providers from accessing necessary patient information, potentially delaying treatment and disrupting patient care and healthcare operations.

Overall Risk: High

8. Security Control Recommendations

Risk 1: Malicious External Actor Compromises Patient Check-In Tablet

- **Network Access Controls:** Implement network access controls to restrict unauthorized devices and network traffic from communicating with the patient check-in tablet.
- **Restricted Administrative Privileges:** Limit administrative privileges on the tablet to prevent unauthorized configuration changes.
- **Physical Security Measures:** Use physical security measures such as security cameras and/or security personnel to deter and identify unauthorized physical tampering with the tablet.

Risk 2: Phishing Attack

- **Multi-Factor Authentication (MFA):** Stolen credentials alone are not enough to access the system.
- **Sender Policy Framework (SPF):** Helps prevent attackers from spoofing Lakeside Medical Center's email domain.
- **Awareness training:** Helps employees identify and appropriately respond to phishing attempts.

Risk 3: Lost or Stolen Device

- **Access Control Restrictions:** Implement access controls that restrict access to patient information and system resources based on authorized users and their assigned permissions. This limits who can access organizational resources.
- **Password Complexity Requirements:** Require strong passwords that meet minimum complexity requirements, such as a specified length and the use of uppercase and lowercase letters, numbers, and special characters. This makes it more difficult for an unauthorized individual to guess or compromise a user's password.
- **Encryption:** Encrypt sensitive patient information stored on devices so that the information remains protected if a device is lost or stolen. Encryption helps prevent unauthorized individuals from viewing or accessing protected information without the appropriate decryption credentials.

Risk 4: Insider Misuse

- **Role-Based and Attribute-Based Access Controls (RBAC/ABAC):** Implement role-based and attribute-based access controls to ensure employees can only access patient information and system resources that are necessary for their specific job functions and assigned responsibilities.
- **Least Privilege:** Implement the principle of least privilege so that employees are provided only the minimum level of access required to perform their job duties. This limits the ability of employees to access patient information that is not necessary for their work.
- **Security Information and Event Management (SIEM):** Implement a SIEM solution to collect and analyze system and user activity logs. This allows Lakeside Medical Center to monitor employee access to patient information, detect unusual access patterns and support investigation of unauthorized access.

Risk 5: System Failure

- **Regular System Updates:** Implement a process for regularly updating and patching the Patient Information System and supporting systems. Regular updates help address security vulnerabilities and reduce the risk of system disruptions caused by outdated software.
- **Load Balancing:** Implement load balancing to distribute system traffic across available servers or resources. This helps prevent individual systems from becoming overwhelmed and supports the availability and performance of the Patient Information System during periods of high demand.
- **Redundancy:** Implement redundant systems and components to provide backup resources if the primary system or component fails. Redundancy helps maintain the availability of the Patient Information System and allows operations to continue during a system failure.

9. Residual Risk Assessment

Risk	Initial Risk	Residual Likelihood	Residual Impact	Residual Risk
Check-in tablet compromise	High	Low	Medium	Low
Phishing/account compromise	High	Low	Medium	Low
Lost or stolen device	Medium	Low	Medium	Low
Insider misuse	Medium	Low	Medium	Low
System failure	High	Low	Medium	Low

After the recommended security controls are implemented, the likelihood and potential impact of each identified risk are expected to decrease, resulting in a lower level of residual risk.

10. Residual Risk Conclusion

The overall assessment shows that Lakeside Medical Center needs to strengthen its cybersecurity controls and protocols to better protect patient information and reduce organizational risk. The assessment identified risks involving phishing attacks, unauthorized access, lost or stolen devices, insider misuse, and system failures. Implementing the recommended security controls can reduce the likelihood and potential impact of these risks and help protect the confidentiality, integrity, and availability of patient information.